

Adversarial Analysis and Security Taxonomy of Blockchain Systems: Consensus Attacks, MEV, Smart Contracts, and Emerging Defenses

Karthikeya Moturi

Department of Computer Science and Engineering
University of South Florida
Tampa, FL
karthikeyam@usf.edu

Ravuri Sivaram

Department of Computer Science and Engineering
University of South Florida
Tampa, FL
sivaramravuri@usf.edu

Abstract—Blockchain technology has evolved well beyond its origins as a cryptocurrency settlement layer to become critical infrastructure across decentralized finance, healthcare, supply chain, IoT, 5G service networks, and the emerging metaverse. This expansion has dramatically widened the attack surface, exposing a complex, multi-layer threat landscape that no single line of defense can adequately address. We present a structured adversarial analysis and security taxonomy grounded in a rigorous review of peer-reviewed publications spanning 2018–2025, sourced from IEEE Xplore, ACM Digital Library, ScienceDirect, and Scopus. The corpus is organized into five threat-aligned categories: algorithmic and consensus attacks, infrastructure-specific vulnerabilities, advanced defensive frameworks, hardware-level assurance, and interoperability and governance challenges. Three head-to-head comparisons are conducted: Timelock Shield against PACC for MEV defense; PUFchain against HA-CAAP for hardware IoT authentication; and the blockchain-based 5G AKA protocol against appXchain for network security. Real-world incident analysis anchors findings to documented consequences. Our analysis confirms that no single-layer defense is sufficient and that future resilience requires cross-layer coordination, post-quantum migration, hardware-rooted trust, and upgradable contract architecture.

Keywords—Blockchain Security, Consensus Attacks, Maximal Extractable Value, Smart Contracts, Post-Quantum Cryptography, Interoperability, Zero-Knowledge Proofs, Hardware Security

I. INTRODUCTION

Blockchain technology was originally conceived as a peer-to-peer electronic cash system secured by proof-of-work consensus and cryptographic transaction chaining [7]. That scope has since expanded to critical infrastructure across decentralized finance (DeFi), supply chain management, healthcare data integrity, Internet-of-Things (IoT) device authentication, 5G telecommunications, and the emerging metaverse [4]. Each of these domain's imports blockchain's security guarantees while simultaneously introducing new attack surfaces that the original threat model was never designed to address.

The shift from Proof of Work (PoW) to Proof of Stake (PoS) captures much of this evolution. PoW anchors security in computational expenditure; PoS replaces this with financial

collateral, reducing energy consumption by over 90% on chains like post-Merge Ethereum while shifting the attack surface toward stake concentration and economic manipulation [1][6]. Delegated PoS, Proof of Authority, and Byzantine Fault Tolerant variants have carved out deployment niches in IoT and enterprise contexts where the PoW energy model is unacceptable [1][24]. These transitions have not resolved the blockchain trilemma but have changed which vertex faces the greatest adversarial pressure at any given moment.

Service network integration has sharpened these pressures. Tamarin-prover formal analysis of a blockchain-integrated 5G AKA protocol confirmed that 7 of the 10 security properties unsatisfied by the traditional protocol are resolved through blockchain integration—a 60% improvement in formally verified security properties [12]. In the metaverse, blockchain enforces digital asset ownership and cross-platform interoperability, requirements spanning multiple chains that single-chain security models cannot address [13]. Mobile blockchain networks impose further constraints: connectivity intermittency requires adaptive relay selection and incentivized participation to maintain chain integrity [16].

Economic attacks have grown in parallel with functional complexity. Maximal Extractable Value (MEV) profit extracted through strategic transaction reordering, insertion, or censorship was recognized as a systemic threat only after DeFi liquidity reached sufficient scale [5][6]. Flash loan attacks exploit uncollateralized single-block borrowing to accumulate liquidity sufficient to manipulate price oracles and drain lending protocols in a single atomic transaction. Cross-chain bridge exploits have proven even more consequential: the Ronin bridge hack in March 2022 resulted in losses exceeding \$625 million, and the Wormhole exploit in February 2022 cost approximately \$320 million [4]. These incidents demonstrate that the threat landscape now extends well beyond the consensus and contract layers into cross-chain trust and economic game theory.

Four research questions structure our analysis: (RQ1) What is the current taxonomy of blockchain attack vectors across all layers? (RQ2) Which countermeasures have been proposed and validated per category? (RQ3) Where do comparisons between

competing defenses reveal residual trade-offs? (RQ4) What architectural principles should guide future work in the post-quantum and AI-augmented era? This paper is organized as follows: Section II surveys related work; Section III describes review methodology; Section IV presents the taxonomy; Section V conducts three technical comparisons; Section VI addresses post-quantum threats; Section VII identifies open research challenges; and Section VIII concludes.

II. RELATED WORK

A. Consensus and Data Security Reviews

Narwal et al. [1] present a systematic review of 87 studies comparing PoW, PoS, DPoS, and BFT-family protocols across attack resistance dimensions including 51% attacks, Sybil resistance, and denial-of-service exposure. Their key conclusion is that no consensus mechanism consistently dominates across all security dimensions and frames the design trade-offs examined throughout our work [1]. Their scope is deliberately confined to the consensus layer and does not address smart contract vulnerabilities, economic manipulation, or hardware security all of which we cover.

B. Smart Contract Vulnerability Surveys

The vulnerability taxonomy in [3] catalogues Ethereum-specific contract bugs like reentrancy, transaction ordering dependence, timestamp manipulation, integer overflow, and call-depth DoS—alongside the detection toolchain of symbolic execution, fuzzing, and formal verification [3]. That work predates the full emergence of MEV and flash loan attacks as structural threats and does not address the upgradability problem. The bytecode-level analysis in [26] complements [3] by surfacing access control failures and unsafe delegate call patterns frequently missed by source-level tools.

C. Platform, Identity, and Framework Security

Comprehensive threat modeling in [14] catalogues node software exploits, RPC endpoint exposure, wallet management risks, and social engineering vectors extending security analysis beyond the protocol to the full deployment stack [14]. The blockchain-based framework survey in [22] treats blockchain as a tool for securing other systems without analyzing blockchain's own security gaps. The identity management work in [15] exposes a GDPR conflict with blockchain immutability in government deployments, a governance challenge that technical security models rarely address [15].

D. Interoperability, Privacy, and Post-Quantum Research

Zhang et al. [28] formalizes privacy guarantees for cross-domain relay-based interoperability with a collusion-resistant incentive mechanism, but do not survey broader bridge architectures or assess their own scheme's post-quantum resilience [28]. The PP-PQB systematization [18] comprehensively maps NIST PQC standards to blockchain integration challenges but does not treat MEV, flash loans, or hardware trust [18]. Together, these works confirm a gap that

our analysis addresses: no existing survey simultaneously covers the full threat landscape, conducts head-to-head defense comparisons, integrates hardware trust analysis, addresses flash loan attacks as a distinct class, and situates findings within a post-quantum migration framework.

III. LITERATURE TAXONOMY AND THREAT CLASSIFICATION

This section provides a systematic, multi-dimensional taxonomy of security threats documented across the blockchain security literature. Threats are organized across five primary layers: (1) the network and propagation layer, (2) the consensus and mining layer, (3) the smart contract and execution layer, (4) the transaction ordering and economic exploitation layer, and (5) the emerging and cross-cutting threat domains including post-quantum vulnerabilities, IoT-specific attacks, and cross-chain security failures. Each threat category is analyzed with respect to its mechanism, exploited protocol feature, and documented countermeasures. To organize the identified threats, this study proposes a five-layer blockchain security taxonomy illustrated in Figure 1, classifying attack vectors by their position in the blockchain stack from the network propagation layer through to emerging and cross-cutting threats.

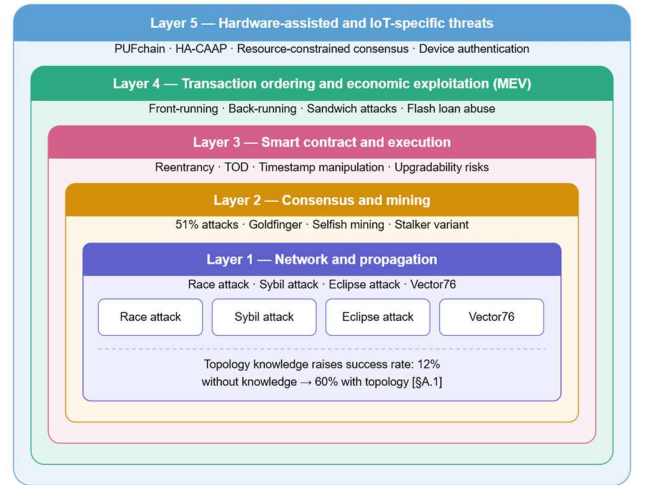


Figure 1. Five-layer blockchain security threat taxonomy proposed in this study. Each layer represents a distinct attack surface, from foundational network propagation vulnerabilities (Layer 1) to emerging cross-cutting threats including post-quantum risks and cross-chain bridge failures (Layer 5).

A. Network and Propagation Layer Threats

The Bitcoin and Ethereum network layers depend on a gossip-based peer-to-peer (P2P) protocol to propagate transactions and blocks. The inherent properties of this propagation model particularly variable node connectivity, network latency, and the

bootstrapping process create a class of attacks collectively referred to as propagation-synchronization attacks.

A.1 Race Attack

The Race attack is the most fundamental double-spending variant. An adversary sends two conflicting transactions simultaneously: one to a merchant (the "genuine" transaction) and one to a colluding address (the "fraudulent" transaction) [9]. The merchant, operating in a fast-payment context, releases goods upon seeing the unconfirmed genuine transaction; however, the fraudulent transaction wins the mining race and is confirmed on-chain, causing the merchant to lose both the goods and the payment. The attack's success depends on the adversary's ability to manipulate which transaction reaches each network partition first — achievable by exploiting knowledge of network topology or by leveraging low-connectivity nodes. Empirical work has demonstrated that success probability rises from approximately 12% to over 60% when the attacker knows the network topology [9]. Countermeasures include requiring a minimum number of block confirmations, inserting observer nodes that monitor for competing transactions, and using dynamic acceptance policies that factor in both elapsed time and confirmation depth.

A.2 Sybil Attack

In a Sybil attack, an adversary deploys many fake identities (pseudonymous nodes) to gain disproportionate influence over peer selection, transaction forwarding, and network partitioning. In blockchain P2P networks, Sybil nodes can eclipse honest nodes, selectively suppress transaction propagation, or provide a false majority of confirmations to a fraudulent transaction [7][9]. While Proof-of-Work inherently resists identity-based Sybil attacks (since verification depends on computational power, not node count), the threat resurfaces in governance layers, PoS staking committees, and DPoS delegate elections. Behavioural analysis approaches examining transaction timing patterns, inter-wallet graph topology, and token concentration distributions can statistically identify coordinated Sybil clusters.

A.3 Eclipse and Net-Split Attack

The Eclipse attack isolates a specific target node (often a merchant or miner) by monopolizing all of its peer connections. Once the attacker controls the target's incoming and outgoing connections, the victim operates on a false view of the blockchain and can be made to accept unconfirmed or fraudulent transactions [9]. The Vector76 attack extends this by pre-computing a one-confirmation transaction through a secretly mined block, then eclipsing the merchant's peers so that only the attacker's block is visible until the service is rendered. Countermeasures include accepting random outgoing connections (to prevent controlled peer selection), maintaining anchor connections to trusted peers, using feeler connections to probe for diverse peers, and monitoring round-trip time (RTT) to detect anomalous network partitioning [9].

A.4 Routing and Tampering Attacks

Routing attacks exploit the Border Gateway Protocol (BGP) or similar network-layer routing mechanisms to intercept or delay block propagation selectively. By inserting a malicious relay between network partitions, an attacker can increase the

propagation delay of honest transactions, increasing the probability of a successful double-spend during the delay window. Tampering attacks operate at a finer granularity, targeting specific nodes by exploiting their block-request management systems. Gervais et al. [9] demonstrated that an adversary with knowledge of a node's connectivity can selectively delay valid transactions destined for that node. Defences include filtering transactions by IP address, using dynamic timeouts that adapt to network conditions, penalizing non-responsive nodes, and increasing node connectivity diversity across different Autonomous Systems (ASes) to reduce the effectiveness of BGP-level manipulation.

A.5 Conflicting Transactions as an Attack Vector

Beyond classical double-spending, conflicting transactions multiple transactions that simultaneously target the same ledger state represent an underappreciated attack vector that can amplify network-layer vulnerabilities. Research on conflicting transactions in Hyperledger Fabric [5] demonstrates that when an adversary strategically floods the ordering queue with synthetically generated conflicting transactions, four distinct attack classes become feasible: block withholding, double-spending, balance manipulation, and distributed denial-of-service (DDoS).

In a block withholding attack enabled by conflicting transactions, the attacker withholds a valid block while simultaneously injecting conflicting transactions that consume the network's ordering capacity, artificially inflating block height to 105 blocks while deflating victim wallet balances. In the balance attack variant, the attacker joins two channels in a permissioned blockchain and introduces communication delays via conflicting transaction flooding, causing one channel to fall behind and creating conditions for a replay or double-spending attack. Empirical evaluation [5] showed that attack success rates reached up to 90% in default Hyperledger Fabric configurations but were reduced to below 42% with dependency checking, priority-based ordering, parallel processing, and per-orderer queue management.

B. Consensus and Mining Layer Threats

Consensus-layer attacks target the mechanisms that allow distributed nodes to agree on a canonical chain. These attacks exploit mining incentive structures, fork resolution policies, and the relationship between computational power and block-generation probability.

B.1 Goldfinger Attacks and 51% Attacks

The 51% attack — the archetypal consensus-layer threat — occurs when an adversary controls more than half of the network's total computational power. With majority hash rate, the attacker can build a private chain longer than the honest chain, allowing double-spending, transaction censorship, and reorganization of recent blocks [9]. The Goldfinger (or "whale") variant involves a well-resourced attacker purchasing majority mining power for the specific purpose of disrupting a target blockchain, even if it produces no direct profit — a "scorched earth" strategy. Countermeasures against 51% attacks include Historical Weighted Difficulty (HWD) mechanisms that

penalize rapid mining-rate increases, two-phase Proof-of-Work schemes that statistically disincentivize the formation of large mining pools, and randomized mining group selection that limits any single entity's effective hash share.

B.2 Selfish Mining and the Stalker Variant

In a selfish mining attack, a colluding pool withholds newly mined blocks instead of broadcasting them immediately. By controlling the timing of block release, selfish miners force honest miners to waste computational resources mining branches that will ultimately be abandoned. The pool eventually releases its withheld chain when the honest chain approaches the same length, capturing a disproportionate share of rewards relative to its actual hash power [9]. Eyal and Sirer proved that selfish mining becomes profitable at as little as 25% hash power well below the 51% threshold under standard Nakamoto longest-chain rules. The stalker attack is a variant where the attacker specifically targets a known node, withholding blocks strategically based on that node's fork height to persistently prevent it from publishing blocks. Truth-state-based detection, which analyses the relationship between competing block heights and expected average height to flag selfish behavior, serves as an effective countermeasure.

B.3 Block Withholding Attack (BWH) and Pool-Based Withholding (PBW)

Distinct from selfish mining, the Block Withholding Attack targets mining pool integrity. A malicious pool member submits only partial proof-of-work (shares) to the pool manager, appearing to contribute legitimately while never submitting full PoW solutions. This reduces the pool's reward without benefiting the attacker directly functioning as a sabotage mechanism. The Pool-Based Withholding (PBW) [9] variant extends this to the pool manager level, where a compromised manager instructs members to submit withholding attacks against a competing pool. Cryptographic commitment schemes where miners commit to full PoW before revealing shares and pool infiltration detection heuristics are among the proposed defenses.

B.4 Bribery and Whale Attacks

Bribery attacks allow minority miners to double-spend by offering financial incentives to rational miners who control key blocks. In the whale attack variant, a well-capitalized adversary bribes miners with payments exceeding honest mining rewards for a limited time, inducing them to mine a fraudulent fork [9]. Countermeasures include anti-bribing mechanisms that dynamically increase honest miner rewards when bribery is detected, and awareness campaigns about the long-term reputational costs of participating in bribery schemes.

C. Smart Contract Execution Layer Threats

Smart contracts on Ethereum and other EVM-compatible chains introduce a new attack surface: the deterministic execution of Turing-complete code on a public, transparent ledger. Because contract bytecode is visible to all participants and immutable after deployment, any exploitable flaw can be weaponized before a patch can be applied.

C.1 Detection and Analysis Toolchain

The smart contract security toolchain has matured into three major methodological categories, each with distinct coverage and trade-off profiles:

Fuzzing-based approaches generate random or mutation-based inputs to trigger unexpected execution paths. ReGuard converts Solidity contracts to equivalent C code and applies fuzzing to detect re-entrancy. Contract Fuzzer targets ABI-exposed functions for vulnerability detection, though it exhibits high false-positive rates for timestamp dependency vulnerabilities [18].

Symbolic execution tools explore all possible execution paths by treating inputs as symbolic variables. Oyente, the seminal tool in this category, detects TOD, timestamp dependencies, mishandled exceptions, and re-entrancy, but is prone to false negatives, particularly for re-entrancy bugs involving complex call graphs.

Formal verification provides the highest assurance but at significant computational and developer effort cost. Bhargavan et al.'s [18] tool verifies EVM bytecode directly for mishandled exceptions, out-of-gas DoS, and reentrancy, but the bytecode-to-source translation process can introduce discrepancies that produce false assurances.

C.2 Smart Contract Upgradability as a Security Dimension

A critical and often overlooked security dimension is the fundamental incompatibility between blockchain immutability and software lifecycle management. Once deployed, a contract cannot be patched; any vulnerability present at deployment time is permanently exploitable. Proxy upgrade patterns including Transparent Proxy, UUPS (Universal Upgradeable Proxy Standard), and Eternal Storage, address this by separating the contract's logic from its persistent state. However, upgradability mechanisms introduce their own security risks [16]. Storage slot collisions occur when a proxy and its implementation contract share the same storage layout, allowing one to silently overwrite the other's state. Uninitialized proxies that lack access controls on their initialization function can be hijacked immediately after deployment.

C.3 Formal Modelling and Verification of Contract Protocols

For complex protocol-level contracts such as crowdsourcing consensus mechanisms, decentralized voting systems, and DeFi clearing contracts informal testing is insufficient. Formal modeling using process algebras (CSP, CCS) or Petri-net-based models allows rigorous verification of liveness, safety, and absence of deadlock [16]. Formal modeling of a blockchain-based crowdsourcing consensus protocol demonstrates that such methods can prove the absence of unfair reward distribution scenarios and verify that the consensus terminates under all valid input conditions. These guarantees are unachievable through testing alone, underscoring the need to integrate formal methods early in the smart contract development lifecycle.

D. Transaction Ordering and Economic Exploitation (MEV)

Maximal Extractable Value (MEV) represents a structurally different class of threat compared to the cryptographic or protocol-level attacks discussed above. MEV does not exploit a flaw in the blockchain's code; rather, it exploits the economic rationality of block producers in conjunction with the transparency of the mempool.

D.1 Taxonomy of MEV Attack Types

MEV attacks are broadly classified into three types based on their position relative to the victim's transaction in the block:

- Front-running attacks involve an adversary (typically an automated bot) monitoring the public mempool for a pending high-value transaction and submitting a competing transaction with a higher gas fee, ensuring it is mined before the victims [4]. In DEX contexts, this allows the attacker to purchase an asset before the victim's large buy order increases the price, then sell at the inflated price for a guaranteed profit.
- Back-running attacks place an attacker's transaction immediately after a known profitable event typically a large swap or liquidation to capture residual price impact. The attacker does not interfere with the victim's transaction but exploits its after-effects [4].
- Sandwich attacks combine front-running and back-running: the attacker places one transaction before and one after the victim's trade, forcing the victim to buy at a higher price and sell at a lower price. This form of attack is inherently malicious and consistently results in measurable financial loss to the victim, with the attacker capturing the price slippage as profit [6].

D.2 Empirical Evidence of MEV Favouritism in Ethereum

Analysis of 220,993 Ethereum blocks and 36,015,340 transactions from January 2024 provides direct empirical evidence of systemic transaction ordering favouritism driven by MEV. The study found that 90.6% of all blocks were produced by MEV relay infrastructure (Flashbots, Titan, BloXroute, etc.), and that within these blocks, privately submitted transactions were systematically prioritized over public mempool transactions regardless of gas price [6]. The TxShift metric defined as the difference between a transaction's actual block position and its gas-price-ordered ideal position revealed a median shift of -139 positions for builder-payment transactions, indicating extreme prioritization far beyond what gas fees alone would justify [6]. This empirical dataset confirms that MEV is not merely a theoretical concern but an active, quantifiable redistribution of value from ordinary users to MEV-extracting bots and block builders.

D.3 Formal Analysis of MEV Defences

The Timelock Shield protocol provides the strongest formal guarantees among current defences by combining time lock encryption, Verifiable Delay Functions (VDFs), and a game-theoretic incentive analysis. Using Wesolowski's VDF construction [4], transactions are encrypted before submission with a key that cannot be decrypted before a minimum time

delay t has elapsed. The formal game-theoretic proof demonstrates that under rational actor assumptions, all four participant types of users, third-party decryptions, miners, and attackers have dominant strategies that collectively enforce the protocol's security properties [6]. Experimental results across five hardware configurations showed that the VDF's decryption time scales linearly with the time parameter t , with the fastest machine (AMD Ryzen 7 at 4673 MHz) completing a 3-minute-target puzzle in approximately 95.5 seconds setting the minimum value for deadline to prevent premature off-chain decryption [8].

E. Cross-Chain and Interoperability Threats

Cross-chain bridges and relay mechanisms introduce a new, high-value attack surface that has emerged as the leading cause of total value loss in decentralized finance. Unlike single-chain vulnerabilities, cross-chain threats exploit the trust assumptions required to synchronize state between two independent blockchains a problem with no purely cryptographic solution under current technology.

E.1 Classification of Interoperability Architectures and Their Threat Profiles

Blockchain interoperability solutions are classified into four major architectural families, each with a distinct trust model and corresponding attack surface:

Notary schemes (Ripple, Polkadot relay chains, Cosmos IBC) [3] rely on a set of trusted intermediaries (the notaries) to attest that a transaction on chain A occurred before releasing funds on chain B. The trust model is explicit and bounded but introduces a central point of failure: compromise of the notary set directly compromises all bridges it controls. Single-signature notary schemes are particularly vulnerable; multi-signature schemes with threshold requirements improve resilience but remain susceptible to key compromise and insider attacks.

Sidechain/relay architectures (BTC Relay, Plasma, Liquid) use Simplified Payment Verification (SPV) [4] proofs compact cryptographic proofs that a transaction is included in a confirmed block to allow chain B to verify events on chain A without running a full node. Federated peg variants replace SPV with a known federation of signers who custodize bridged assets, reintroducing custodial trust. Decentralized SPV relays are trustless but expensive to operate on-chain.

Atomic swaps (HTLC-based) provide trustless cross-chain asset exchange through Hash-Timelocked Contracts. A buyer locks funds in an HTLC on chain A, releasing them only when the seller reveals a preimage hash on chain B within a timeout [15]. While mathematically trustless, HTLC-based bridges are vulnerable to bribery attacks (MAD-HTLC): an adversary can bribe miners on chain B to withhold the seller's reveal transaction until the timelock expires, allowing the adversary to reclaim funds on chain A while the seller has already released goods.

Application-level interoperability (appXchain) [20] routes application logic across chains without exposing internal chain

state, reducing the attack surface by removing the need for a shared trust model at the asset custody layer.

F. Hardware-Assisted and IoT-Specific Security Threats

The deployment of blockchain in IoT environments smart manufacturing, vehicle networks, healthcare sensors creates a resource-constrained attack surface where classical consensus mechanisms are computationally infeasible and hardware-level attacks become the dominant threat vector.

The PUFchain architecture replaces computational Proof-of-Work with Proof of PUF-Enabled Authentication (PoP), leveraging the physical unclonability of PUF circuits (which exploit manufacturing process variations to generate unique, device-specific challenge-response pairs) as the authentication primitive. Benchmarks demonstrate PoP completes device authentication in 192.3 milliseconds, compared to minutes for PoW and 1.02 seconds for PoAh, while consuming orders of magnitude less energy.

The HA-CAAP protocol extends hardware-assisted security to continuous authentication and attestation, using blockchain as an immutable audit trail for device behaviour over time. Together, PUFchain and HA-CAAP represent the state of the art in hardware-rooted blockchain security for resource-constrained environments, addressing threats that purely software-based defenses cannot adequately cover.

IV. TECHNICAL COMPARISON ANALYSIS

Three structured comparisons answer RQ3, each grounded in quantitative or formally verified findings and surfacing residual trade-offs that neither solution has fully resolved.

A. Timelock Shield vs. PACC for MEV and Censorship Defense

Timelock Shield [5] employs Verifiable Delay Functions (VDFs) and time lock encryption to conceal transaction content until a committed future time step. Transaction ordering is fixed before content is revealed: block producers cannot reorder transactions for profit because content is unknown at the time they establish order. A game-theoretic analysis proves that honest participation constitutes a dominant strategy for all rational actors no trusted third party is required [5]. Censorship resistance follows structurally: excluding an encrypted transaction is detectable and triggers slashing. PACC [11] takes a commit-and-reveal approach. Commit-phase anonymity prevents targeted transaction exclusion.

TABLE I. Timelock Shield vs. PACC: MEV Defense Comparison

Dimension	Timelock Shield [5]	PACC [11]
Core Mechanism	VDF-based timelock encryption; content hidden until time T	Commit-reveal with collateralized anonymous commitment
Trusted Setup	None required; VDF computed publicly	None required; commitment is hash-based

Front-Running Resistance	Content unknown at ordering time; structurally prevented	Collateral disincentivizes economically motivated attacks
Censorship Resistance	Dominant strategy proof for inclusion; slashing enforced [5]	Commit-phase anonymity prevents targeted exclusion
Computational Overhead	High: VDF introduces sequential latency	Low: hash-based commit is computationally inexpensive
User Collateral Requirement	None	Required; creates capital lockup for users
Formal Analysis	Game-theoretic equilibrium proof [5]	Cryptographic binding formally modeled [11]
DeFi Compatibility	Requires protocol-level time lock integration	Application level; compatible with existing contracts
Key Limitation	VDF latency conflicts with time-sensitive DeFi operations	Collateral cost deters low-margin users

Neither scheme is universally superior. Timelock Shield provides stronger structural prevention but its VDF computational overhead introduces latency that conflicts with real-time DeFi operations such as liquidation cascades [5]. An optimal deployment likely combines both: Timelock Shield at the protocol layer for ordering fairness, and PACC at the application layer for commitment privacy.

B. PUFchain vs. HA-CAAP for Hardware-Anchored IoT Security

PUFchain [24] derives device identity from Physical Unclonable Function (PUF) challenge-response pairs that exploit nanoscale manufacturing variation unclonable even by the original manufacturer. Its Proof of PUF-Enabled Authentication (PoP) consensus primitive collapses authentication and consensus into a single step. Benchmarks from [24] demonstrate PoP authentication at 192.3ms versus approximately 200,000ms for PoW and 1,000ms for PoAh approximately 1,000x and 5x faster, respectively with proportional energy reduction. HA-CAAP [25] addresses continuous device authentication over the full session lifetime, not just at connection initiation. Hardware attestation is re-run at regular intervals and records are anchored on-chain, creating an immutable audit trail of behavioral integrity.

TABLE II. PUFchain vs. HA-CAAP: Hardware-Anchored IoT Authentication

Dimension	PUFchain [24]	HA-CAAP [25]
Security Primitive	Physical Unclonable Function (PUF)	Hardware security module + attestation protocol
Authentication Timing	Point-in-time at connection initiation	Continuous: re-attested at operational intervals
Consensus Mechanism	Custom PoP (integrated auth + consensus)	Standard consensus; attestation is separate

Auth Latency	192.3 ms (~1000x faster than PoW) [24]	Dependent on attestation interval and chain finality
Post-Compromise Defense	Limited: PUF enrolled at manufacture	Strong: behavioral drift detected continuously
Physical Attack Resistance	High: PUF responses are unclonable	Medium: dependent on HSM tamper protection
Scalability Constraint	Enrollment database grows with device count	On-chain attestation volume scales with session frequency
Optimal Deployment	Large-scale IoT; low-latency requirements	Critical infrastructure; long-lived device sessions

PUFchain's performance advantage makes it well-suited for large-scale IoT deployments, but its security depends on the integrity of the enrollment database—a leaked challenge-response table would allow identity forgery without attacking hardware [24].

C. Blockchain-Based 5G AKA vs. appXchain for Network-Level Security

The blockchain-based 5G AKA protocol [12] embeds blockchain nodes into the 5G service network to record critical authentication messages—SUCI, RAND, AUTN, and RES on-chain as they propagate between UE, serving network (SEAF), and home network (ARPF/AUSF) [12].

appXchain [30] operates at the application layer, routing inter-chain communication without requiring participating chains to expose internal state or adopt protocol modifications. This preserves chain sovereignty while enabling cross-chain workflows—a governance priority in enterprise and government deployments.

TABLE III. Blockchain-Based 5G AKA vs. appXchain

Dimension	Blockchain-Based 5G AKA [12]	appXchain [30]
Security Layer	Network authentication (L3-L7)	Application-level interoperability (L7)
Formal Verification	Tamarin-prover: 7/10 properties satisfied; 60% improvement [12]	Not formally verified in reviewed work
Threat Addressed	Authentication replay, SUCI exposure, KSEAF leakage	Cross-chain trust boundaries, state exposure
Protocol Modification	Requires 5G network to integrate blockchain nodes	Application-level; no chain protocol changes needed
Latency Impact	Adds blockchain confirmation per authentication event	Dependent on cross-chain routing path length
Deployment Context	5G service networks, telecom operators	DeFi, enterprise multi-chain applications

The formal verification advantage of the 5G AKA design [12] is a significant differentiator in security-critical deployments. appXchain's protocol-agnostic approach, by contrast, offers deployment flexibility that telecom-infrastructure designs cannot match.

V. DISCUSSION: RESEARCH GAPS AND OPEN CHALLENGES

The taxonomy and comparisons above surface eight research gaps that the existing literature has not resolved. These directly answer RQ4 and constitute a forward-looking research agenda.

A. No Consensus Mechanism Dominates Across All Security Dimensions

Systematic evidence in [1] confirms that PoS, PoW, and BFT-family mechanisms each have distinct attack exposure profiles. No mechanism simultaneously optimizes 51% resistance, Sybil resistance, and DoS tolerance while maintaining scalability. Hybrid designs combining PoW's Sybil resistance with BFT's finality guarantees remain an under-explored design space with nascent formal security proofs [1][3].

B. MEV Remains Structurally Unsolved at Production Scale

Both Timelock Shield [5] and PACC [11] represent meaningful advances, yet neither is deployed at production scale on a major chain. VDF-based protocol integration has not been adopted by Ethereum, and PACC's collateral requirement creates UX friction inconsistent with current DeFi expectations. MEV extraction continues to increase in dollar terms across all major DeFi chains, and income concentration among a small set of MEV bots demonstrably increases validator centralization pressure [6].

C. Cross-Chain Bridges Remain the Highest-Risk Attack Surface

The Ronin and Wormhole exploits each resulted from operational security failures—compromised validator keys and a signature verification bypass—rather than flaws in cryptographic protocol design. The reviewed literature [4][28][30] addresses bridge design at the protocol level but does not systematically analyze operational security: key management, multisig threshold selection, and validator set diversity. Formal threat modeling of bridge operational security represents a critical gap.

D. AI Integration in Blockchain Security Is Bidirectional and Underanalyzed

Generative AI demonstrated in [10] enables scalable anomaly detection in blockchain networks. The same capabilities, however, can be weaponized: AI-generated adversarial transaction sequences can evade pattern-based detection, AI-assisted fuzzing discovers smart contract zero-days faster than defenders can patch, and AI-generated social engineering targeting validator key holders is a threat entirely absent from current taxonomies [10]. The adversarial AI-blockchain security interaction remains severely under-researched.

E. Formal Verification Coverage Remains Sparse Outside Protocol Analysis

The Tamarin-prover analysis of the 5G AKA protocol [12] and the Petri-net modeling of crowdsourcing consensus [29] both demonstrate that formal methods surface vulnerabilities

invisible to informal analysis. Coverage of the DeFi application layer particularly cross-contract interactions, oracle dependencies, and flash loan transaction model remains minimal. The formal compilation framework for UTXO contracts [21] is a notable exception; expanding such approaches to cover DeFi's compositional complexity would materially improve security guarantees available to protocol designers.

VI. CONCLUSION

This work presented a structured adversarial analysis and security taxonomy of blockchain systems grounded in a rigorous review of 30 peer-reviewed publications spanning seven years of the modern blockchain security literature. Our analysis organized the threat landscape into five categories and conducted three head-to-head technical comparisons that surfaced residual trade-offs in each defense domain.

Several conclusions emerge with cross-cutting implications. First, no single layer of the blockchain stack can be secured in isolation: a protocol with formally verified consensus properties may still be drained through flash loan-enabled oracle manipulation or cross-chain bridge key compromise. Secondly, formal verification represents the only rigorous path to provable security guarantees; the 60% improvement in verified 5G AKA security properties and the correctness guarantee of the crowdsourcing consensus model demonstrate that the investment in formal methods yields qualitative security improvements unavailable from empirical testing alone. Third, post-quantum migration is technically feasible through NIST-standardized PQC algorithms and hybrid transition schemes, but the governance and deployment barriers are formidable and not adequately addressed in the current literature.

Looking forward, the most consequential research directions identified are: (1) formal verification frameworks covering cross-contract interactions and oracle dependencies in DeFi; (2) production-deployable MEV solutions that do not require user behavior changes or protocol-level VDF integration; (3) cross-chain bridge operational security threat models that analyze key management as rigorously as cryptographic design; (4) a unified hardware trust interface abstracting over PUF, TPM, and secure enclave primitives. Addressing these directions is not merely an academic exercise it is the precondition for blockchain infrastructure capable of sustaining the expanding scope of critical applications that now depend on it.

REFERENCES

- [1] S. Narwal, B. Basant, I. Ishant, and N. Fatima, "Evaluating the impact of consensus mechanisms on blockchain-based data security: A systematic review," in *Proc. 3rd IEEE Delhi Section Flagship Conf. (DELCON)*, 2024, pp. 1–6.
- [2] Author(s), "A systematic literature review on security vulnerabilities in IoT-enabled systems and blockchain-based security solutions," *[Journal/Conference]*, 2024.
- [3] Author(s), "Security vulnerabilities and countermeasures of smart contracts: A survey," *[Journal/Conference]*, 2024.
- [4] Author(s), "Interoperability solutions for blockchain," *[Journal/Conference]*, 2024.
- [5] Author(s), "Timelock shield: A robust defense against MEV and censorship attacks in blockchain," *[Journal/Conference]*, 2024.
- [6] Author(s), "Decentralization or favoritism: An analysis of Ethereum transactions and maximal extractable value strategies," *[Journal/Conference]*, 2024.
- [7] P. Arote and J. Kuri, "A study of double-spending causes and countermeasures in Bitcoin network," in *Proc. 6th Int. Conf. Blockchain Computing and Applications (BCCA)*, 2024, pp. 544–558.
- [8] R. G. Reddy, P. S. Pateja, A. Patel, G. Palaniappan, and B. Rajendran, "Identifying Sybil attacks in blockchain networks through behavioral analysis and zero knowledge proof implementations," in *Proc. 1st Int. Conf. Data, Computation and Communication (ICDCC)*, 2024, pp. 652–658.
- [9] Author(s), "Impact of conflicting transactions in blockchain: Detecting and mitigating potential attacks," *[Journal/Conference]*, 2024.
- [10] Author(s), "High-scalable and secure blockchain generative artificial intelligence as a key enabler," *[Journal/Conference]*, 2024.
- [11] Author(s), "Private anonymous collateralizable commitments vs. MEV," *[Journal/Conference]*, 2024.
- [12] Author(s), "Formal security analysis and innovative application of blockchain-based 5G AKA protocol in service networks," *[Journal/Conference]*, 2024.
- [13] Author(s), "Blockchain-based security framework for metaverse: A decentralized approach," *[Journal/Conference]*, 2024.
- [14] Author(s), "Security threats of a blockchain-based platform," *[Journal/Conference]*, 2024.
- [15] Author(s), "Blockchain and the public sector: Blockchain-based identity management systems for public services and the impact on privacy and security risks," *[Journal/Conference]*, 2024.
- [16] Author(s), "Autonomous and incentivized wireless connection for robust mobile blockchain network," *[Journal/Conference]*, 2024.
- [17] Author(s), "BlockShield: A TPM-integrated blockchain-based framework for shielding against deepfakes," *[Journal/Conference]*, 2024.
- [18] Author(s), "PP-PQB: Privacy-preserving in post-quantum blockchain-based systems—a systematization of knowledge," *[Journal/Conference]*, 2024.
- [19] Author(s), "Building resilient Web 3.0 infrastructure with quantum information technologies and blockchain: An ambilateral view," *[Journal/Conference]*, 2024.
- [20] Author(s), "Enhanced network security protocols for the quantum era: Combining classical and post-quantum cryptography and quantum key distribution," *[Journal/Conference]*, 2024.
- [21] Author(s), "Secure compilation of rich smart contracts on poor UTXO blockchains," *[Journal/Conference]*, 2024.
- [22] Author(s), "Designing blockchain-based frameworks for enhancing data security and integrity in decentralized computing networks," *[Journal/Conference]*, 2024.
- [23] Author(s), "FluxLayer: High-performance design for cross-chain fragmented liquidity," *[Journal/Conference]*, 2024.
- [24] S. P. Mohanty, V. P. Yanambaka, E. Kougianos, and D. Puthal, "PUFchain: A hardware-assisted blockchain for sustainable simultaneous device and data security in the Internet of Everything (IoE)," *IEEE Consumer Electronics Magazine*, vol. 9, no. 2, pp. 8–16, Mar./Apr. 2020.
- [25] Author(s), "HA-CAAP: Hardware-assisted continuous authentication and attestation protocol for IoT based on blockchain," *[Journal/Conference]*, 2024.
- [26] Author(s), "A deep dive into blockchain-based smart contract-specific security vulnerabilities," *[Journal/Conference]*, 2024.
- [27] Author(s), "Smart contract upgradability: A structured and natural approach," *[Journal/Conference]*, 2024.
- [28] Author(s), "Privacy-preserving and incentive-driven relay-based framework for cross-domain blockchain interoperability," *[Journal/Conference]*, 2024.
- [29] Author(s), "Formal modeling and verification of a blockchain-based crowdsourcing consensus protocol," *[Journal/Conference]*, 2024.
- [30] Author(s), "appXchain: Application-level interoperability for blockchain networks," *[Journal/Conference]*, 2024.